AI Agent Onboarding Checklist

Inventory, approve, and govern every agent before it goes live

Nexus Security Advisors · November 2026

Why this exists

Every AI agent is a non-human identity. It should be onboarded, reviewed, and offboarded with the same discipline as a person. Most organizations already have that process for employees. Almost none have it for agents.

Broad "just for the pilot" access is the root cause of most cleanup problems later. Scope it tightly on day one, and offboarding becomes routine rather than an archaeology project.

> **The data:** in Arrakis Security's 2026 sample of production agents, 76% had not run in 60 days, 70% connected to at least one sensitive integration, and 19% used keys or tokens that never expire. About a quarter of dormant agents could still be started through an unsigned webhook. In Pax8's 2026 survey, 35% of small businesses found AI running without approval in the past six months.

How to use it: run Step 0 once to build your register. Use the onboarding list for every new agent, and the review section on your normal access-review schedule. When an agent needs to be retired, switch to the companion Offboarding Checklist. Every agent needs a named human owner who signs off at each stage.

> **Companion document:** this is one half of a pair. Use it with the AI Agent Offboarding Checklist from Nexus Security Advisors. Both are free at nexussecurityadvisors.com/checklists.

Step 0: Inventory every agent

You can't govern an agent you don't know exists.

Done	Checklist item	Owner	Date
☐	Pull agents from every place they live: AI platforms (Copilot Studio, custom GPTs, agent builders), automation tools (Zapier, Make, n8n, Power Automate), cloud functions, and code repos		
☐	Review OAuth app consents and API key lists in core SaaS (Microsoft 365, Google Workspace, Salesforce, Slack) for agent-held grants		
☐	Check for local agents and MCP servers on developer machines and browser extensions with AI features		
☐	Ask each team directly which agents or automations they built or use		
☐	Record each agent in a register with the fields below		

Register field	What to record
Agent name and purpose	One line on what it does and for whom
Human owner and backup	A named person, not a team

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Register field	What to record
Risk tier	Low, moderate, or high, based on the data and systems it touches
Platform and location	Where it runs and where its code or configuration lives
Identity and credentials	Service account, API keys, OAuth grants, and whose grant it runs on
Connected systems	Every integration, with sensitive ones flagged
Triggers and callers	Schedules, webhooks, events, and other agents that can start or call it
Data it stores	Memory, vector stores, logs, files
Status and dates	Approved, expected end date, last run, credential expiry, next review

Onboarding: before an agent goes live

Agent record			
Agent name		**Risk tier**	
Owner		**Backup owner**	
Platform		**Expected end date**	

Done	Checklist item	Owner	Date
Approval and ownership			
☐	Business purpose and expected end date documented		
☐	Named human owner and a backup owner assigned		
☐	Risk tier set by the data and systems it touches		
☐	Security sign-off for moderate and high tiers		
Identity and access			
☐	Dedicated non-human identity per agent, never a shared account or a person's login		
☐	Least-privilege scopes: read-only unless writing is required, limited to the specific folders, tables, or channels needed		
☐	If it runs on a person's OAuth grant, that dependency is recorded in the register		
☐	Secrets kept in a secrets manager, out of prompts, code, and the agent's own runtime where possible		
☐	Every key and token has an expiry date, with nothing set to never expire		
☐	Short-lived or just-in-time credentials for sensitive actions, as the joint CISA, NSA, and Five Eyes agentic AI guidance recommends		

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Done	Checklist item	Owner	Date
☐	Agent-to-agent calls documented: which agents it can call or be called by, and under whose credentials. A downstream agent must not do what the calling agent can't (OWASP ASI03)		
Triggers, tools, and actions			
☐	Every trigger listed, with webhooks signed or authenticated		
☐	High-impact actions (payments, deletions, external email, permission changes) need human approval		
☐	Rate and spend limits set		
☐	Tools, plugins, connectors, and MCP servers are approved, from a known publisher, and pinned to a version (OWASP ASI04)		
Data			
☐	Data classes it can read and store defined		
☐	Retention set for memory, vector stores, and logs		
☐	Vendor and model data-use terms reviewed		
☐	Data loss prevention (DLP) or equivalent monitoring covers every sensitive connection		
☐	Rules for what can be written to long-term memory, so poisoned or sensitive content does not persist (OWASP ASI06)		
Visibility and control			
☐	Actions logged and attributable to the agent's identity		
☐	Kill switch documented and tested, with the owner able to use it		
☐	Guardrails tested before launch: try prompt injection and fake secrets and confirm they don't get through		
☐	Offboarding plan noted now: what triggers retirement and what happens to its data		

While it runs: review on the same schedule as user access

Agents belong in the same access review as people, at the same cadence. Quarterly works for most organizations. Review high-risk agents monthly.

Done	Checklist item	Owner	Date
☐	Agent still appears in the register, with owner confirmed		
☐	Still needed for its stated purpose		
☐	Scopes still match what it actually uses, with unused permissions removed		

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Done	Checklist item	Owner	Date
☐	Credentials are within their expiry and rotated on schedule		
☐	Last-run date checked: no run in 30 days is flagged to the owner; no run in 60 days starts offboarding unless the owner justifies keeping it		
☐	Seasonal agents (quarter-end close, annual audit evidence, open enrollment) tagged so the dormancy rule does not retire them by mistake		
☐	Logs reviewed for unexpected actions, data access or trigger sources		
☐	Spend and token use compared to the last period; a spike with no business reason is treated as a possible compromise		
☐	Any new integrations or triggers since the last review were approved; a significant change in purpose or data means re-onboarding		

Onboarding sign-off			
Agent owner		**Date**	
Security		**Date**	
Next review		**Register updated**	

Use cases

The same process covers very different agents. These patterns come up most often.

Scenario	What usually goes wrong	Where to focus at onboarding
HR or IT help desk agent built in a low-code studio for a 90-day pilot	Pilot ends, agent stays published with access to HR policies and employee records	Expected end date; owner; read-only scopes
Marketing automation (Zapier, Make, n8n) built by a contractor	Runs on the contractor's OAuth grant and outlives their contract	Record whose grant it uses; move it to a service identity
Finance agent that reads invoices and drafts payments	Write access to payments with no approval step; a target for invoice fraud and goal hijack	High risk tier; human approval; monthly review
Security operations (SOC) triage agent with EDR or firewall write access	Prompt injection through alert content triggers containment on the wrong hosts	Approval for disruptive actions; tested kill switch
Customer support agent with CRM and outbound email	Leaks customer data or makes unapproved commitments	Data classes, DLP, memory rules, external-email approval
Coding agent with repo write access and CI/CD secrets	Secrets copied into configs and logs; unvetted tools or MCP servers	Secrets manager; pinned, approved tools

Pros and cons of running this process

This is not free. Be clear with leadership about the trade-offs, then decide how much rigor each risk tier needs.

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Benefits	Costs and trade-offs
Closes the dormant-access exposure most organizations never see until an incident	Adds steps for every agent. If approval takes weeks, people build on personal accounts, and shadow AI grows
Reuses processes you already run (access reviews, HR leaver workflows), so it needs process changes more than new tools	The register needs an owner and regular upkeep. A stale register gives false comfort
Produces audit evidence for NIST SP 800-53 AC-2, ISO/IEC 42001, SOC 2 access controls, and cyber insurance questionnaires	Many platforms still run agents on a user's login or OAuth grant, so a clean per-agent identity may not be possible yet
Faster incident response: you know who owns the agent, what it can touch, and how to stop it	Some native agent governance features add licensing cost (Microsoft Entra agent sponsor workflows require Microsoft 365 E7 or Agent 365)
Visibility into spend: idle agents get caught and retired	A strict dormancy rule can retire seasonal agents unless owners tag them
Leadership can keep saying yes to new AI use because there is a defined way to govern it	Owner sign-off can turn into a rubber stamp. Spot-check a sample each cycle

Bottom line: scale the process to the risk tier. A low-risk agent that summarizes public documents needs an owner, an expiry date, and a register entry. A high-risk agent that moves money needs all of it.

What can go wrong with onboarding

Most failures here are process failures, not tool failures.

What goes wrong	How it shows up	How to head it off
Inventory misses agents	Agents on personal accounts, browser extensions, local MCP servers, or a vendor's platform never reach the register	Pull OAuth consents and key lists quarterly; ask teams directly; pair with shadow AI discovery
Pilot access becomes permanent	Broad "temporary" scopes are never reduced after launch	Set the end date and scope review at approval, not later
Approval too slow	Teams route around the process and build unapproved agents	Fast-track the low-risk tier; publish a clear request path
Kill switch fails under pressure	During an incident, nobody knows how to stop the agent, or the switch only pauses the interface	Test it at onboarding and after major platform changes
Scope creep without re-approval	A read-only reporting agent gains write access or new data over time	Treat a significant change as a new onboarding

Framework mapping

Mapped at the control family level. Check exact control IDs against your own scope.

Framework	What it requires	Where it shows up
NIST SP 800-53 Rev. 5, AC-2	Defined account owners, approval, periodic review, and disabling accounts that are no longer needed	Inventory, ownership, reviews

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

Framework	What it requires	Where it shows up
NIST CSF 2.0 (ID.AM, PR.AA)	Inventories of systems and services; identities and credentials for users and services managed; least-privilege access	Inventory, identity, and access
NIST AI RMF 1.0	Accountability, an inventory of AI systems, and safe decommissioning (Govern, Map, Manage)	Ownership, register, risk tier
ISO/IEC 42001:2023	An AI management system covering the full AI life cycle, including retirement	The full life-cycle process
ISO/IEC 27001:2022 Annex A (5.15, 5.16, 5.18, 8.2, 8.5)	Access control, identity management, provisioning and removal of access rights, privileged access, secure authentication	Identity, access, reviews
OWASP Non-Human Identities Top 10 (2025)	NHI1 Improper Offboarding, NHI5 Overprivileged NHI, NHI7 Long-Lived Secrets, NHI9 NHI Reuse, NHI10 Human Use of NHI	Dedicated identity, expiry dates
OWASP Top 10 for Agentic Applications 2026	ASI03 Identity & Privilege Abuse, ASI04 Agentic Supply Chain, ASI06 Memory & Context Poisoning, ASI10 Rogue Agents	Delegation, tools, memory rules
OWASP LLM06:2025 Excessive Agency	Limit an agent's functionality, permissions, and autonomy	Least privilege, human approval
CISA, NSA, and partners: Careful Adoption of Agentic AI Services (May 2026)	A unique, verifiable identity per agent; access limited to the task; temporary credentials for sensitive actions	Identity, short-lived credentials

Sources

- Forgotten AI agents may still access sensitive company data, Help Net Security on the Arrakis Security 2026 Autonomous Agents Threat Report (vendor telemetry from thousands of production agents over 12 weeks), October 26, 2026.
- Pax8 Research Finds Small Businesses Are Building AI Faster Than They Can Govern It, Pax8 Q3 2026 SMB AI Pulse Report, 1,150 small business leaders in the US, UK, Germany, and Sweden, October 2026.
- OWASP Top 10 Non-Human Identities Risks (2025), OWASP Foundation.
- OWASP Top 10 for Agentic Applications for 2026, OWASP GenAI Security Project, December 2025.
- LLM06:2025 Excessive Agency, OWASP Top 10 for LLM Applications 2025.
- Careful Adoption of Agentic AI Services, CISA, NSA, and partner agencies from Australia, Canada, New Zealand, and the UK, May 1, 2026.
- AML.T0083 Credentials from AI Agent Configuration, MITRE ATLAS.
- NIST SP 800-53 Rev. 5, NIST AI RMF 1.0, NIST CSF 2.0, and ISO/IEC 42001:2023.

Additional resources

- Accelerating the Adoption of Software and AI Agent Identity and Authorization, NIST NCCoE concept paper, February 2026. Where federal guidance on agent identity, authorization, and non-repudiation is heading.
- Agentic AI Identity and Access Management: A New Approach, Cloud Security Alliance, August 2025. A reference architecture for agent identity in multi-agent systems.
- Agent identity sponsor tasks in Lifecycle Workflows, Microsoft Learn. Moves agent sponsorship automatically when the human sponsor changes roles or leaves.

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.

- Nexus Security Advisors readiness checklists, including AI governance, CMMC, HIPAA, SOC 2, and cyber insurance.

A note on the numbers: the Arrakis figures come from the vendor's own customer telemetry and the Pax8 figures from a vendor-run survey. Treat them as useful signals, not independent research, and check them against your own register before they go in front of a board.

Need help standing this up? Nexus Security Advisors helps growing businesses put AI governance in place without slowing adoption. Request a consultation.

Free to use and adapt. Provided as general guidance, not legal advice. Validate control mappings against your own scope.